

TASK 6: Social Engineering Awareness Guide

Social engineering is a cyberattack technique in which attackers manipulate people into revealing confidential information, providing unauthorized access, or performing actions that compromise security. Instead of attacking only technical systems, social engineers exploit human emotions such as fear, trust, curiosity, and urgency.

2. Common Social Engineering Techniques

2.1 Phishing

Phishing involves sending fraudulent emails or messages that appear to come from trusted organizations to trick people into revealing passwords, financial information, or other sensitive data.

Warning signs:

- Suspicious links or unexpected attachments.
- Unfamiliar or misleading sender addresses.
- Requests for passwords, OTPs, or banking details.
- Urgent messages threatening account suspension.

Prevention: Verify the sender, avoid suspicious links, and access services through their official websites or applications.

2.2 Pretexting

Pretexting occurs when an attacker creates a false identity or believable story to obtain sensitive information. For example, someone may pretend to be an IT support employee and request login credentials.

Warning signs:

- Unexpected requests for confidential information.
- Unverified claims of authority.
- Requests to bypass normal security procedures.

Prevention: Verify the person's identity through an official communication channel before sharing information.

2.3 Baiting

Baiting uses something attractive, such as free downloads or an unknown USB drive, to encourage a victim to perform an unsafe action.

Warning signs:

- Unknown USB drives found in public areas.
- Offers that seem too good to be true.
- Downloads from untrusted websites.

Prevention: Never connect unknown storage devices or download suspicious files.

2.4 Impersonation

In impersonation attacks, an attacker pretends to be a manager, colleague, vendor, or trusted authority to persuade someone to reveal information or transfer money.

Warning signs:

- Unexpected requests from supposedly senior employees.
- Unusual payment or data-sharing instructions.
- Requests to keep an action secret.

Prevention: Confirm unusual requests directly with the person using a known phone number or official channel.

2.5 Tailgating

Tailgating occurs when an unauthorized person follows an authorized employee into a restricted physical area without proper authentication.

Warning signs:

- Someone asking to enter using another person's access card.
- Unknown visitors following employees through secure doors.
- People avoiding visitor registration.

Prevention: Follow access-control procedures, do not share access cards, and report suspicious activity to security personnel.

3. Common Warning Signs of Social Engineering

- Urgency: The message pressures you to act immediately.
- Impersonation: The sender pretends to be someone trustworthy.
- Suspicious requests: You are asked for passwords, OTPs, confidential files, or money.
- Secrecy: You are told not to inform your manager or security team.
- Unexpected links: Messages contain unusual URLs or attachments.
- Emotional manipulation: The attacker uses fear, excitement, curiosity, or authority to influence your decision.

4. Real-World Scenarios

Scenario 1: - Fake Bank Message: An employee receives a message claiming their bank account will be blocked unless they verify their credentials through a link. This may be a phishing attempt. The employee should avoid the link and contact the bank through its official channel.

Scenario 2: - Fake IT Support Call: Someone claiming to be from IT asks an employee to disclose an OTP to fix an account problem. The employee should never share the OTP and should verify the request with the actual IT team.

Scenario 3: -Urgent Payment Request: An employee receives an unexpected message supposedly from the company manager requesting an immediate money transfer. The employee should independently verify the request before taking action.

Scenario 4: -Unknown USB Drive: An employee finds a USB drive in the office parking area. It may contain malicious files. The employee should not connect it to a work computer and should report it to the IT team.

5. Best Practices to Prevent Social Engineering

1. Verify the identity of anyone requesting sensitive information.
2. Never share passwords, OTPs, or authentication codes.
3. Avoid clicking suspicious links or downloading unexpected attachments.

4. Confirm urgent financial requests through a separate, trusted channel.
5. Use multi-factor authentication to protect accounts.
6. Follow organizational access-control and data-sharing policies.
7. Report suspicious emails, calls, messages, and visitors promptly.
8. Participate in cybersecurity awareness training.